SRI LANKA INSTITUTE OF INFORMATION TECHNOLOGY

FACULTY OF COMPUTING.

WEB SECURITY- IE2062

IT22121592 – HERATH H.M.C.H.K

Y2S2

Contents

What is bug bounty? 2

1- Vulnerability title. 7

2- Vulnerability description. 7

3. Affected components. 9

4- Impact assessment. 10

5- Steps to reproduce. 12

6- Proposed mitigation or fix. 13

What is bug bounty?

Bug bounty programs are initiatives that enable people, like hackers and security researchers to identify and report security gaps or flaws in a company's software or websites for a reward such as cash prizes or recognition in exchange for disclosing these issues to the company running the program for improving their security measures through external testing, by researchers.

Here are the important elements of a bug bounty initiative.

- Focused on security measures – the objective is to identify and address vulnerabilities such, as site scripting (CSS) SQL injection attacks and authentication gaps.

- Ethical Hacking involves individuals referred to as hackers or "white hats" who are authorized to conduct security assessments on a company's resources, in search of potential vulnerabilities.

- Compensation, for researchers is determined by the seriousness and significance of the vulnerabilities they discover with the amount of reward varying according to the criticality of the issue found.

- Responsible Reporting Guidelines instruct researchers to adhere to protocols, for revealing vulnerabilities by notifying the company in private to disclosing any specific information publicly.

Many known tech companies and platforms such, as Google and Facebook frequently organize bug bounty programs with the assistance of platforms, like HackerOne or Bugcrowd.

I conducted security on the main domain ‘bigcommerce.com’ as part of my bug bounty research. I used tools like ‘Sublist3r, amaas’ to scan the main domain.

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ whois bigcommerce.com
   Domain Name: BIGCOMMERCE.COM
   Registry Domain ID: 3488368_DOMAIN_COM-VRSN
   Registrar WHOIS Server: whois.safenames.net
   Registrar URL: http://www.safenames.net
   Updated Date: 2024-03-01T03:24:52Z
   Creation Date: 1999-02-08T05:00:00Z
   Registry Expiry Date: 2026-02-08T05:00:00Z
   Registrar: SafeNames Ltd.
   Registrar IANA ID: 447
   Registrar Abuse Contact Email: abuse@safenames.net
   Registrar Abuse Contact Phone: +44.1908200022
   Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
   Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
   Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
   Name Server: DNS2.P01.NSONE.NET
   Name Server: NS-CLOUD-D1.GOOGLEDOMAINS.COM
   Name Server: NS-CLOUD-D2.GOOGLEDOMAINS.COM
   Name Server: NS-CLOUD-D3.GOOGLEDOMAINS.COM
   DNSSEC: unsigned
   URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2024-10-17T15:31:55Z <<<
```

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ python3 /usr/bin/sublist3r -d bigcommerce.com
```

```
[-] Total Unique Subdomains Found: 86
www.bigcommerce.com
about.bigcommerce.com
api.bigcommerce.com
apps.bigcommerce.com
bcanalytics.bigcommerce.com
blog.bigcommerce.com
blog-mt.bigcommerce.com
careers.bigcommerce.com
www.careers.bigcommerce.com
cdn1.bigcommerce.com
cdn1-ci.bigcommerce.com
cdn1-gi.bigcommerce.com
cdn1-i.bigcommerce.com
cdn10.bigcommerce.com
cdn100.bigcommerce.com
cdn11.bigcommerce.com
cdn12.bigcommerce.com
cdn2.bigcommerce.com
cdn2-ci.bigcommerce.com
cdn2-gi.bigcommerce.com
cdn2-i.bigcommerce.com
```

```
┌──(jeon㉿demo)-[~]
└─$ nmap -sV -sC -T4 bigcommerce.com
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-17 14:18 +0530
Nmap scan report for bigcommerce.com (63.141.128.3)
Host is up (0.060s latency).
Other addresses for bigcommerce.com (not scanned): 192.200.160.253
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE SERVICE  VERSION
80/tcp   open  http     Cloudflare http proxy
|_http-server-header: cloudflare
|_http-title: Did not follow redirect to https://www.bigcommerce.com/
443/tcp  open  ssl/http Cloudflare http proxy
|_http-server-header: cloudflare
|_http-title: 400 The plain HTTP request was sent to HTTPS port
| ssl-cert: Subject: commonName=*.bigcommerce.com/organizationName=BigCommerce, Inc./stateOrProvinceName=Texas/countryName=US
| Subject Alternative Name: DNS:*.bigcommerce.com, DNS:bigcommerce.com
| Not valid before: 2024-03-08T00:00:00
|_Not valid after:  2025-03-06T23:59:59
```

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ amass enum -d bigcommerce.com
bigcommerce.com (FQDN) --> a_record --> 192.200.160.253 (IPAddress)
bigcommerce.com (FQDN) --> a_record --> 63.141.128.3 (IPAddress)
bigcommerce.com (FQDN) --> mx_record --> alt1.aspmx.l.google.com (FQDN)
bigcommerce.com (FQDN) --> mx_record --> aspmx3.googlemail.com (FQDN)
bigcommerce.com (FQDN) --> mx_record --> aspmx.l.google.com (FQDN)
bigcommerce.com (FQDN) --> mx_record --> aspmx2.googlemail.com (FQDN)
bigcommerce.com (FQDN) --> mx_record --> alt2.aspmx.l.google.com (FQDN)
bigcommerce.com (FQDN) --> ns_record --> dns2.p01.nsone.net (FQDN)
bigcommerce.com (FQDN) --> ns_record --> ns-cloud-d3.googledomains.com (FQDN)
bigcommerce.com (FQDN) --> ns_record --> ns-cloud-d1.googledomains.com (FQDN)
bigcommerce.com (FQDN) --> ns_record --> ns-cloud-d2.googledomains.com (FQDN)
cdn.bigcommerce.com (FQDN) --> cname_record --> cdn-bigcommerce-com-lb.gcp.bigcommerce.net (FQDN)
info.bigcommerce.com (FQDN) --> cname_record --> www1-bigcommerce-com-1496300288.us-east-1.elb.amazonaws.com (FQDN)
developer-beta.bigcommerce.com (FQDN) --> cname_record --> dev-center-lb.gcp.bigcommerce.net (FQDN)
login.bigcommerce.com (FQDN) --> cname_record --> shared-lb-lb1.gcp.bigcommerce.net (FQDN)
manage.bigcommerce.com (FQDN) --> cname_record --> shared-lb-lb1.gcp.bigcommerce.net (FQDN)
developer.bigcommerce.com (FQDN) --> cname_record --> dev-center-lb.gcp.bigcommerce.net (FQDN)
careers.bigcommerce.com (FQDN) --> cname_record --> phcreative-dzavffavg8eafgdq.z01.azurefd.net (FQDN)
support.bigcommerce.com (FQDN) --> cname_record --> support.bigcommerce.com.00d30000001fdcgea4.live.siteforce.com (FQDN)
www.bigcommerce.com (FQDN) --> cname_record --> www.bigcommerce.com.cdn.cloudflare.net (FQDN)
connect.bigcommerce.com (FQDN) --> cname_record --> bigcommerce.beyondtrustcloud.com (FQDN)
devtools.bigcommerce.com (FQDN) --> cname_record --> shared-lb-global-lb1.gcp.bigcommerce.net (FQDN)
newsletter.bigcommerce.com (FQDN) --> cname_record --> sendgrid.net (FQDN)
staging.bigcommerce.com (FQDN) --> cname_record --> www-stage-bigcommerce-com-1973200124.us-east-1.elb.amazonaws.com (FQDN)
grow.bigcommerce.com (FQDN) --> cname_record --> bigcommerce.mktoweb.com (FQDN)
microapps.bigcommerce.com (FQDN) --> cname_record --> microapp-cdn.gcp.bigcommerce.net (FQDN)
mail11.bigcommerce.com (FQDN) --> a_record --> 34.68.202.102 (IPAddress)
chat.bigcommerce.com (FQDN) --> cname_record --> d1fst8v83vh1i2.cloudfront.net (FQDN)
mail9.bigcommerce.com (FQDN) --> a_record --> 34.68.202.102 (IPAddress)
mailer.bigcommerce.com (FQDN) --> a_record --> 104.195.84.14 (IPAddress)
payments.bigcommerce.com (FQDN) --> cname_record --> payments-lb.gcp.bigcommerce.net (FQDN)
mail5.bigcommerce.com (FQDN) --> a_record --> 34.68.202.102 (IPAddress)
cdn1.bigcommerce.com (FQDN) --> cname_record --> cdn1.bigcommerce.com.cdn.cloudflare.net (FQDN)
start.bigcommerce.com (FQDN) --> cname_record --> startbigcomprd.wpengine.com (FQDN)
cdn6.bigcommerce.com (FQDN) --> cname_record --> cdn6.bigcommerce.com.cdn.cloudflare.net (FQDN)
security.bigcommerce.com (FQDN) --> cname_record --> bigcommerce.portals.safebase.io (FQDN)
grc.bigcommerce.com (FQDN) --> cname_record --> bigcommerce.datagrail.io (FQDN)
personas.bigcommerce.com (FQDN) --> cname_record --> primal-mayflower-aqskjwzn08hgmcxvj9wzx32d.herokudns.com (FQDN)
dam.bigcommerce.com (FQDN) --> cname_record --> bigcommerce.bynder.com (FQDN)
partnernews.bigcommerce.com (FQDN) --> cname_record --> big-commerce.portal.impartner.co.uk (FQDN)
emb.bigcommerce.com (FQDN) --> a_record --> 192.28.144.165 (IPAddress)
account.bigcommerce.com (FQDN) --> cname_record --> manage.bigcommerce.com (FQDN)
education.bigcommerce.com (FQDN) --> cname_record --> store-eeehna47at.mybigcommerce.com (FQDN)
dev.bigcommerce.com (FQDN) --> a_record --> 34.102.196.0 (IPAddress)
192.200.160.0/24 (Netblock) --> contains --> 192.200.160.253 (IPAddress)
```

During my reconnaissance phase, I selected 10 subdomains associated with the main domain. There are:

1. Cdn1.bigcommerce.com
2. Payments.bigcommerce.com
3. Shop.bigcommerce.com
4. login.bigcommerce.com
5. grow.bigcommerce.com
6. content.product.bigcommerce.com
7. design.bigcommerce.com
8. chat.bigcommerce.com
9. account.bigcommerce.com
10. manage.bigcommerce.com

Each of these subdomains was analyzed for potential security vulnerabilities and any identified issues will be detailed in the subsequent section of the this report.

My first subdomain was ‘cdn1.bigcommerce.com’

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ nslookup cdn1.bigcommerce.com 8.8.8.8
Server:         8.8.8.8
Address:        8.8.8.8#53

Non-authoritative answer:
cdn1.bigcommerce.com    canonical name = cdn1.bigcommerce.com.cdn.cloudflare.net.
Name:   cdn1.bigcommerce.com.cdn.cloudflare.net
Address: 192.200.160.253
Name:   cdn1.bigcommerce.com.cdn.cloudflare.net
Address: 63.141.128.3
```

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ ping cdn1.bigcommerce.com
PING cdn1.bigcommerce.com.cdn.cloudflare.net (63.141.128.3) 56(84) bytes of data.
64 bytes from 63.141.128.3: icmp_seq=1 ttl=57 time=47.8 ms
64 bytes from 63.141.128.3: icmp_seq=2 ttl=57 time=24.7 ms
64 bytes from 63.141.128.3: icmp_seq=3 ttl=57 time=31.5 ms
64 bytes from 63.141.128.3: icmp_seq=4 ttl=57 time=44.3 ms
64 bytes from 63.141.128.3: icmp_seq=5 ttl=57 time=29.2 ms
64 bytes from 63.141.128.3: icmp_seq=6 ttl=57 time=28.0 ms
```

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ dig content.product.bigcommerce.com @8.8.8.8

; <<>> DiG 9.19.21-1-Debian <<>> content.product.bigcommerce.com @8.8.8.8
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 29993
;; flags: qr rd ra; QUERY: 1, ANSWER: 4, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;content.product.bigcommerce.com. IN    A

;; ANSWER SECTION:
content.product.bigcommerce.com. 525 IN CNAME   5716810793353216-content.customer.pendo.io.
5716810793353216-content.customer.pendo.io. 255 IN CNAME cdn-cname.pendo.io.
cdn-cname.pendo.io.     255     IN      CNAME   51.138.111.34.bc.googleusercontent.com.
51.138.111.34.bc.googleusercontent.com. 3600 IN A 34.111.138.51

;; Query time: 224 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Fri Oct 18 15:10:58 +0530 2024
;; MSG SIZE  rcvd: 205
```

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ curl -I https://cdn1.bigcommerce.com
HTTP/2 404
date: Fri, 18 Oct 2024 09:32:07 GMT
content-type: text/plain
content-length: 9
etag: "669f4b4f-9"
x-request-id: 09928a08f030a138093290840aa47662
access-control-allow-origin: *
access-control-max-age: 604800
cache-control: public, max-age=30
cf-cache-status: EXPIRED
bc-ray: 1
server: cloudflare
cf-ray: 8d4784f2bb3db2ff-CMB
alt-svc: h3=":443"; ma=86400
```

1- Vulnerability title.

The CROS header- Access-control-allow-origin.

```
x-request-id: 09928a08f030a138093290840aa47662
access-control-allow-origin: *
access-control-max-age: 604800
```

2- Vulnerability description.

"What does CORS refer to?"

Cross-Origin Resource Sharing (or CORS, for short) is a security measure integrated into web browsers to block web pages from sending requests to domains than the one that originally displayed the page safeguarding against API calls or data access by malicious websites, from different origins.

By default, in web development settings a webpage is not allowed to fetch content, from another domain (known as a origin request). Nonetheless servers have the capability to indicate which domains are permitted to retrieve their content by configuring the CORS headers.

What is the purpose of the Access Control Allow Origin header, with a value of asterisk ?

The use of the header Access Control Allow Origin, with an asterisk allows any website domain to connect to the server and retrieve data without restrictions, on access rights.

Every domain can access the resource by setting Access Control Allow Origin to, which eliminates origin protection concerns.

What makes it a weakness?

When using Access Control Allow Origin as * it may be suitable, for sharing confidential resources such as public images or static content. However, it can pose a security threat, in some situations.

Potential Data Vulnerability:

If the server holds any information, like user profiles or account details and authentication tokens are involved in the process of access requests from sources are allowed then there is a risk that malicious websites could exploit this to make unauthorized requests, to your server and obtain the retrieved information.

A harmful website might deceive a user who is already logged in into sending a request to a server (such as https://api.example.com/userinfo) allowing it to access data if the Access Control Allow Origin header is configured.

Dealing with Cross Request Forgery (CSRF):

When paired with security weaknesses such, as CSRF (Site Request Forgery) the wildcard configuration can enable malicious actors to submit verified requests in place of a user and retrieve the corresponding data.

For instance, when a user is signed in and a harmful website sends a request to ‘https://api.example.com/delete account ‘the server might handle the request. Send back a reply because the check, for origin is circumvented by *.

Third-party Script Misuse:

Malicious codes, from websites have the ability to send requests to your website and retrieve information from the response data provided by your server.This can pose a risk, for APIs that handle user data intended for specific applications or domains.

Lack of visibility:

It becomes challenging to monitor and trace the websites requesting access, to your server when any source is permitted to do this could lead to domains gaining access and potentially misusing your data.

3. Affected components.

The Access Control Allow Origin header plays a role, in Cross-Origin Resource Sharing (or CORS) a security measure used by web browsers to control how web pages can access resources from various origins (domains). Now let's delve into the aspects of the CORS header mentioned in your response.

CORS Header Breakdown:

1. Access- Control – Allow- origin:

This heading shows that the content is available, to any source using an asterisk (*) as a placeholder that permits all websites to send requests, to this server without any limitations.

The consequences are as follows:

Security Concerns: Enabling access, from all sources may make sharing resources convenient. Also opens up security vulnerabilities when there is information at stake. Unauthorized requests from websites could pose a threat, to the server's security.

In applications, this configuration is commonly employed in APIs to enable access, to resources, by various web applications.

What This Means for cdn1.bigcommerce.com

When you see the CORS header Access-Control-Allow-Origin: on cdn1.bigcommerce.com, it’s like giving a blanket invitation to everyone on the internet. Here’s what that really means in everyday language:

1- Open Door Policy: Think of cdn1.bigcommerce.com as a big storage room filled with images, styles, and scripts that online stores need. With the "*" in the CORS header, it's saying, "Come on in! Anyone can grab what they want." This makes it super easy for developers to access resources, but it also means that not-so-friendly visitors can come in, too.
2- Security Risks: While it's nice to share, this open-door policy can lead to problems. Imagine leaving your front door unlocked—your friends can come over anytime, but so can anyone else. If sensitive or private information is stored here, it could get into the wrong hands. So, while sharing is caring, we need to be cautious about who we let in!
3- Everyone's Invited to the Party: Any website can ask for resources from cdn1.bigcommerce.com. It's like throwing a big party where anyone can join. This is great for collaboration, but it also means that if a shady site wants to sneak in and access something it shouldn't, it can easily do so.
4- Caching Confusion: The server's caching rules are like a shared community fridge. If you put something in there, everyone can use it, but if someone takes it out and forgets to replace it, you're left with stale leftovers. So, if the original resource changes or disappears, people might still see the old version for a while, leading to confusion.
5- Not Found! Error: Right now, if someone tries to access something that isn't there, they'll get a "404 Not Found" message. It's like asking a friend for a book they don't own; sure, you can ask, but they can't lend you something that isn't in their library. This can be frustrating for users who see the CORS policy allowing access but end up hitting a dead end.
6- Impact on Other Websites: Other websites relying on cdn1.bigcommerce.com for their images and styles might find their pages looking broken or incomplete if the expected resources aren't available. It's like trying to watch a movie but finding out that half the scenes are missing—definitely not a good experience!

4- Impact assessment.

When discussing the CORS header Access Control Allow Origin, on cdn1.bigcommerce.com about its impact on stakeholders akin to ripples in a pond. Here's a deeper dive, into the potential consequences;

1 - Challenges, with Trust, from Users: Customers rely on their retailers to safeguard their personal data securely and maintain their trust intact. Discovering that a retailer's lax CORS policies have led to data exposure could significantly impact customer confidence. It's akin, to

entering a store and witnessing the cashier walk away, from the cash register. An experience that might prompt reconsideration before making purchases there.

2- Potential Risks Associated with Exposing Data: There's a risk of access, to information by malicious individuals. If unauthorized individuals manage to infiltrate the system and gain access to data like details or payment information. It could lead to identity theft or fraud with grave repercussions for users and businesses alike. It's akin, to having a burglar in your home who is aware of where you stash your possessions.

3- The consequences of a reputation: If vulnerabilities such, as these are taken advantage of it may harm the reputation of BigCommerce and its sellers significantly. When a security breach occurs and becomes knowledge it can have a lasting impact. Once trust is broken it's not easy to regain. Imagine a scenario where a restaurant receives feedback due, to food contamination; rebuilding customer trust after such an incident takes time.

4- Potential Financial Ramifications: The repercussions of a data breach can result in setbacks, for organizations. Well beyond fines for inadequate safeguarding of user information businesses may need to invest resources in rectifying the situation enforcing stronger security measures and even providing restitution to impacted clients. It's akin to footing a bill, for neglecting a problem that snowballed into a major ordeal.

5- Effect on Developers: When developers depend heavily on this Content Delivery Network (CDN) the unrestricted Cross Origin Resource Sharing (CORS) policy may result in confusion and challenges arising for them to address properly if resources suddenly vanish or get altered without warning—it could potentially lead to malfunctioning websites and dissatisfied visitors like attempting to assemble a jigsaw puzzle only to discover that certain pieces are absent or no longer slot, into place correctly; such situations can result in project delays and additional pressure, for developers grappling with problem-solving tasks.

6- Navigating Regulatory Compliance Hurdles: In some areas, businesses could be, under watch by authorities if they fail to safeguard user data Laws such as GDPR or CCPA impose stringent rules on data security If there is a breach caused by a lenient CORS policy may trigger inquiries and fines It's similar, to getting stopped for speeding—you could get fined if you're not abiding by the traffic regulations

7- The Influence of Community: Ultimately this vulnerability doesn't just harm companies. Also has a ripple effect, on the wider community of users and developers who rely on the platform for their work and interactions online. A breach in security can instill a sense of fear and doubt among people causing them to be extra careful when it comes to sharing their information on the internet. It's akin, to living in a neighborhood where a crime has occurred. Everyone becomes wary and reluctant to participate.

5- Steps to reproduce.

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ curl -I https://cdn1.bigcommerce.com
HTTP/2 404
date: Fri, 18 Oct 2024 09:23:48 GMT
content-type: text/plain
content-length: 9
etag: "669f4c84-9"
x-request-id: 3c4204cfa1bbf1cac69c408b3602582b
access-control-allow-origin: *
access-control-max-age: 604800
cache-control: public, max-age=30
cf-cache-status: EXPIRED
bc-ray: 1
server: cloudflare
cf-ray: 8d4778bedb9c4cb5-CMB
alt-svc: h3=":443"; ma=86400
```

6- Proposed mitigation or fix.

Here are suggestions to address the CORS vulnerability linked to the Access Control Allow Origin header for a platform such, as cdnl.bigcommerce.com:

1 - Limit Permitted Sources: Of relying on we should instead list out a set of approved sources that can access the resources. This approach restricts access, to those domains that are recognized and reliable. By way of illustration: Make sure to allow access for https;//trusted site.com by setting the Access Control Allow Origin header in your code. You could set up a system that checks dynamically and provides the source depending on the Origin header in the request.

2 - Enforce CORS Whitelisting: Develop a list of approved domains that have permission to access your resources. Once you receive a request, from an origin that matches any of the entries, in the whitelist give permission for access, if not reject the request. This guarantees that authorized apps are able to communicate with your server. Exercise caution when disclosing your credentials.

To reduce the risk of misuse, from approved sources or locations set up restrictions, on the number of requests received from each source. This measure can deter denial of service attacks. Minimize the effects of any actions.

3 - Checking the availability of resources: Regularly check which resources are accessible, through CORS making sure essential or public resources can be reached and that sensitive information is properly safeguarded.

It's an idea to separate resources in a way that keeps data secure by hosting it separately and ensuring it's not accessible, through CORS protocols.

4 - Don't forget to include security headers: Add security headers, like Content Security Policy and X-Content Type-Options to boost security measures and reduce the vulnerability to risks linked with cross-origin requests.

5 - Provide Security Training: Make sure that the developers and teams involved in the application grasp the significance of CORS and the need, for setups; ongoing training sessions can assist in maintaining a focus, on security measures.

Keep track and record Cross-Origin Resource Sharing (CORS) requests.

Establish monitoring and logging for Cross-Origin Resource Sharing (CORS) requests to detect any patterns or potential misuse enabling the detection of unauthorized access attempts or abuse through the analysis of these logs.

Make sure to utilize HTTPS. It's always a practice to use HTTPS for serving resources in order to safeguard data while its being transmitted online which helps enhance security and prevents access or alterations, to the data during its journey, over the internet.

6 - Consistently, Revise security protocols: Make sure to check and adjust your CORS policies and server settings from time to time to stay ahead of security threats effectively Be sure to carry out security evaluations and penetration tests to pinpoint any potential weaknesses.